

هم‌رسان: نسخه‌های بین‌سازمانی و سازمانی، و رمزنگاری پیامک

گزارش کار انجام‌شده، راهنمای استفاده از نسخه فعلی، موارد مورد نیاز از منتور و پرسش‌های باز · تاریخ: ۱۴۰۵/۰۷/۰۶ · نسخه سند: ۲

هدف این سند: شرح کامل آنچه برای نسخه‌های بین‌سازمانی و سازمانی ساخته شده است: نسخه‌ها و توزیع، بخش امن، روند دقیق رمز کردن پیامک، بانک کلید، پیام رمز گروهی و دفترچه مخفی. در بخش ۹ راهنمای تصویری استفاده از نسخه فعلی آمده تا ببینید برنامه الان دقیقاً چطور کار می‌کند و اگر جایی با نظر شما فرق دارد، اعلام کنید. بخش‌های ۱۲ و ۱۳ فهرست آنچه باید از طرف شما برسد و پرسش‌هایی است که پیش از نسخه نهایی به نظر شما نیاز دارند. اصطلاحات فنی به همان صورت انگلیسی نوشته شده‌اند.

۱. خلاصه

- هم‌رسان یک کد واحد است با سه نسخه که در قالب دو فایل نصبی (APK) عرضه می‌شود: تجاری (فروشگاه)، بین‌سازمانی (همان فایل تجاری که با کد فعال‌سازی باز می‌شود) و سازمانی (فایل جداگانه، توزیع مستقیم).
- قابلیت‌های امن ساخته‌شده: کد فعال‌سازی؛ بخش امن رمز شده با آیکون قفل؛ رمزنگاری پساکوانتومی پیامک؛ بانک کلید و ابزار ویندوزی صدور کلید؛ پیام رمز یک‌به‌یک (با «دیده شد»، «حذف برای هر دو» و «حذف پس از دیدن»); پیام رمز گروهی؛ دفترچه تلفن و سوابق تماس مخفی.
- همه الگوریتم‌ها استاندارد هستند و با بردارهای آزمون رسمی NIST و RFC آزموده شده‌اند. ۶۵۶ تست خودکار Dart و ۸۹ تست Kotlin/JVM همه موفق‌اند. قابلیت‌ها روی گوشی واقعی (Samsung SM-A336E) و شبیه‌ساز اندروید اجرا شده‌اند.
- باقی‌مانده: (۱) کلید عمومی مرجع اصلی که باید از طرف شما ساخته و تحویل شود؛ تا آن زمان نسخه نهایی هیچ فایل کلیدی را نمی‌پذیرد. (۲) آزمون ارسال پیامک رمز روی شبکه واقعی با دو گوشی و سیم‌کارت، که به بعد موکول شده است.

۲. نسخه‌ها و روش توزیع

نسخه	چگونه به گوشی می‌رسد	قابلیت‌های امن
تجاری	فروشگاه‌ها (بازار، مایکت)	ندارد
بین‌سازمانی	همان فایل تجاری؛ با کد فعال‌سازی داخل برنامه باز می‌شود	دارد
سازمانی	فایل نصبی جداگانه، فقط توزیع مستقیم (هرگز در فروشگاه نیست)	دارد (بدون نیاز به کد فعال‌سازی)

- شناسه و امضای مشترک:** هر دو فایل با شناسه `ir.hamrasan.app` و یک کلید امضا (signing key) ساخته می‌شوند. فروشگاه در هر حالت برنامه را «نصب‌شده» می‌بیند و نصب نسخه سازمانی روی نسخه تجاری بدون از دست رفتن اطلاعات انجام می‌شود (روی گوشی آزموده شد).
- نسخه سازمانی هرگز با نسخه فروشگاه جایگزین نمی‌شود:** شماره نسخه داخلی (versionCode) نسخه سازمانی 2,000,000,000 + N و نسخه تجاری N است. فروشگاه فقط شماره بزرگ‌تر را پیشنهاد می‌دهد و اندروید نصب شماره کوچک‌تر را رد می‌کند (آزموده شد: `INSTALL_FAILED_VERSION_DOWNGRADE`). به‌روزرسانی‌های سازمانی روی هم نصب می‌شوند و اطلاعات می‌ماند. در «درباره برنامه» نوع نسخه («سازمانی») و شماره نسخه دیده می‌شود.
- نسخه سازمانی با هیچ سرور شخص ثالثی ارتباط ندارد:** گزارش خطا (Crash reporting) از این نسخه کاملاً حذف شده است و کد آن اصلاً داخل فایل نصبی نیست.

- اسکریپت‌های ساخت نسخه نهایی پس از ساخت، شناسه، شماره نسخه و امضا را دوباره بررسی می‌کنند و فایلی را که کلید مرجع آزمایشی داخلش باشد رد می‌کنند.

کد فعال‌سازی نسخه بین‌سازمانی (ردیف ۱ پیوست فنی)

به تصمیم مالک پروژه، قالب دقیق کد فعال‌سازی نرم‌افزار قبلی شما (S2MS / Activation.java) بدون تغییر حفظ شده تا برنامه ویندوزی شما بدون تغییر کار کند:

مرحله	مقدار
کد دستگاه (نمایش در برنامه)	BLAKE3(ANDROID_ID)، ۳ بایت اول، هگز کوچک ← ۶ نویسه
ترکیب	یک‌درمیان با شناسه برنامه 111111 ← ۱۲ نویسه
کد فعال‌سازی	BLAKE3(رشته ترکیبی)، ۵ بایت اول، هگز کوچک ← ۱۰ نویسه

- مسیر: تنظیمات ← «درباره برنامه» ← «نسخه بین‌سازمانی» (فقط در فایل تجاری). ورودی کد به حروف بزرگ و کوچک، فاصله، خط تیره و ارقام فارسی حساس نیست. «غیرفعال کردن» هم وجود دارد.
- کد در هر بار خواندن دوباره با همان دستگاه بررسی می‌شود. انتقال اطلاعات به گوشی دیگر یا بازگشت به تنظیمات کارخانه یعنی «فعال نیست».
- با کدهایی که کد جاوای مرجع شما ساخته روی گوشی و شبیه‌ساز آزموده شد؛ با خود برنامه ویندوزی شما هنوز آزموده نشده (بخش ۱۲).

محدودیت شناخته‌شده: چون روش ساخت کد داخل فایل نصبی است، کسی که فایل فروشگاهی را مهندسی معکوس کند می‌تواند کد بسازد. سرور یا امکان باطل کردن کد هم وجود ندارد (پرسش ۷).

۳. بخش امن (Secure section)

- **آیکون قفل** بالای همه زبانه‌ها فقط در نسخه‌های امن است (ردیف ۳). قفل بسته یعنی هیچ نشانه‌ای از محتوای رمز. قفل باز یعنی «پیام‌های رمز»، «دفترچه مخفی» و «تماس‌های مخفی» ظاهر می‌شوند.
- **باز شدن با رمز ورود برنامه (PIN)**، که در نسخه‌های امن ۶ رقمی است. پس از ۵ تلاش اشتباه، انتظار از ۳۰ ثانیه شروع و هر بار دو برابر می‌شود تا ۳۰ دقیقه. این محدودیت برای همه صفحه‌های رمز مشترک است.
- **ذخیره‌سازی:** یک پایگاه‌داده جدای رمز شده (SQLCipher, AES-256). کلید آن ۳۲ بایت تصادفی است که دو لایه قفل شده: (۱) AES-256-GCM با کلید ساخته شده از PIN (PBKDF2-HMAC-SHA256، ۲۱۰,۰۰۰ دور)؛ (۲) کلید سخت‌افزاری Android Keystore StrongBox در صورت وجود که از گوشی خارج نمی‌شود. کپی فایل روی دستگاه دیگر نه باز می‌شود و نه قابل حدس زدن است.
- **قاعده اصلی:** هیچ اطلاعات محرمانه‌ای در پایگاه‌داده اصلی برنامه یا حافظه پیامک و سوابق تماس سیستم (OS) نوشته نمی‌شود.
- **قفل خودکار** با خروج از برنامه. وقتی بخش امن باز است، تصویر صفحه (screenshot) و تصویر فهرست برنامه‌های اخیر سیاه است (FLAG_SECURE)، و متن پیام‌های رمز قابل انتخاب یا کپی نیست (ردیف ۲۲). صفحه‌کلید هم اجازه یادگیری کلمات این متن‌ها را ندارد.
- **فراموشی PIN:** ورود به برنامه با کد بازیابی ممکن است، ولی **محتوای بخش امن از بین می‌رود**، چون هر راه بازیابی در عمل یک در پشتی است (پرسش ۱۳). حذف عمدی بخش امن هم از تنظیمات ← «بخش امن» ممکن است.

۴. رمزنگاری پیامک: روند کامل

نیاز اعلام شده شما رمزنگاری نامتقارن و پساکوانتومی بود. به جای طراحی الگوریتم جدید، ترکیب ترکیبی (hybrid) الگوریتم‌های استاندارد به کار رفته است: پیام فقط وقتی شکسته می‌شود که هر دو بخش کلاسیک و پساکوانتومی شکسته شوند.

کاربرد	الگوریتم
توافق کلید (key exchange)	X25519 (RFC 7748) + ML-KEM-768 (FIPS 203)
امضای مرجع روی دفترچه کلید	Ed25519 (RFC 8032) + ML-DSA-65 (FIPS 204)؛ هر دو امضا باید معتبر باشند
رمز کردن هر پیام	AES-256-GCM؛ رمز و تشخیص دستکاری با هم
ساخت کلید	HKDF-SHA256 (RFC 5869)؛ برای رمز فایل و عبارت عبور: Argon2id (RFC 9106) با ۶۴ مگابایت حافظه
کتابخانه	Bouncy Castle 1.86 (متن‌باز و شناخته‌شده)

۴-۱. کلید هر عضو

هر عضو یک جفت‌کلید بلندمدت دارد: ML-KEM-768 (کلید عمومی ۱۱۸۴ بایت) و X25519 (۳۲ بایت). کلید عمومی کامل ۱۲۱۷ بایت است. شناسه کلید (key id) ۸ بایت اول SHA-256 آن است و بسته‌ها فرستنده و گیرنده را با همین شناسه مشخص می‌کنند. کلید خصوصی به شکل seed (۹۷ بایت) فقط در بخش امن نگهداری می‌شود. منبع کلیدها بانک کلید است (بخش ۵).

۴-۲. برقراری کانال امن (handshake)، یک بار برای هر دو نفر

درخواست (INIT) از الف به ب شامل شناسه جلسه (۲ بایت)، شناسه کلید هر دو طرف، یک کلید X25519 موقت، و متن رمز ML-KEM که فقط ب می‌تواند باز کند. حجم ۱۱۴۱ بایت، ۱۰ قطعه پیامک.	پاسخ (RESPONSE) از ب به الف همین ساختار در جهت عکس، به‌علاوه یک کد تأیید ۱۶ بایتی. ب بلافاصله آماده ارسال است. حجم ۱۱۵۷ بایت، ۱۱ قطعه.	کلید جلسه HKDF روی ۲ راز ML-KEM و ۳ ترکیب X25519 (موقت×ثابت در دو جهت و موقت×موقت)، با نمک (salt) از هش هر دو بسته. هر طرف فقط وقتی به کلید می‌رسد که بسته ویژه خودش را باز کند، پس هویت دو طرف بدون امضا تأیید می‌شود.	خودکار و نامرئی اولین پیام به هر شخص خودش درخواست را می‌فرستد و پیام در گفتگو «در حال برقراری کانال امن» می‌ماند تا پاسخ برسد. اگر دو طرف هم‌زمان درخواست بدهند، درخواست با شناسه کلید کوچک‌تر برنده است. درخواست بی‌پاسخ پس از ۲۴ ساعت دوباره فرستاده می‌شود.
---	--	---	--

۴-۳. کلید جدا برای هر پیام (ردیف ۱۳)

- برای هر جهت یک زنجیره کلید (hash ratchet) وجود دارد: کلید پیام از HMAC زنجیره ساخته می‌شود و زنجیره یک قدم جلو می‌رود. از کلید جدید نمی‌توان به کلید قبلی رسید. کلید هر پیام با HKDF به کلید AES-256 و nonce تبدیل می‌شود و فقط یک بار به کار می‌رود.
- کلیدها برای هر مخاطب هم جدا هستند: هر جفت کاربر کانال و زنجیره خودش را دارد.
- پیام‌هایی که جابه‌جا برسند (تا ۱۰۰۰ پیام جلوتر) درست خوانده می‌شوند و حداکثر ۱۰۰۰ کلید رد شده نگهداری می‌شود. پیام تکراری (اپراتور گاهی دو بار تحویل می‌دهد) یک بار ثبت می‌شود. پیام دستکاری شده رد می‌شود و وضعیت کانال تغییر نمی‌کند.
- ترتیب ایمن: وضعیت جدید کانال همیشه قبل از ارسال پیامک ذخیره می‌شود، پس حتی اگر برنامه وسط کار بسته شود، هیچ کلیدی دو بار استفاده نمی‌شود.

۴-۴. قالب پیامک رمز

بخش	قالب
-----	------

ظاهر پیامک	E: # و سپس Base64 بدون = ؛ فقط نویسه‌های GSM-7، پس هر پیامک ۱۶۰ نویسه و هر قطعهٔ پیامک چندبخشی ۱۵۳ نویسه
بایت اول	نسخهٔ پروتکل × ۱۶ + نوع بسته. نوع: ۱ پیام، ۲ INIT، ۳ RESPONSE، ۴ کنترلی
سرآیند پیام	شناسهٔ جلسه (۲ بایت) و شمارهٔ پیام (LEB128)؛ هر دو در برابر دستکاری محافظت می‌شوند (AAD)
بدنه	متن رمزشده و برچسب GCM (۱۶ بایت)
محتوای رمزشده: نوع	0x01 متن UTF-8؛ 0x02 متن با کدپیچ فارسی (هر حرف فارسی ۱ بایت؛ شکل و نویسه‌های دیگر با پیشوند 0xFF). برنامه هر کدام را که کوتاه‌تر باشد انتخاب می‌کند.
محتوای رمزشده: پرچم‌ها	0x80 حذف پس از دیدن؛ 0x40 پیام گروهی (۸ بایت شناسهٔ گروه پیش از متن)
بسته‌های کنترلی	0x10 «دیده شد» (جلسه، تا شمارهٔ n)؛ 0x11 «حذف برای هر دو» (جلسه، شمارهٔ n)؛ 0x12 مشخصات گروه

بسته	اندازه	قطعه پیامک
درخواست / پاسخ کانال امن	۱۱۴۱ / ۱۱۵۷ بایت	۱۰ / ۱۱ (یک بار برای هر دو نفر)
پیام	۲۱ بایت + متن	۱ پیامک تا حدود ۹۶ حرف فارسی (پیامک فارسی عادی: ۷۰)
«دیده شد»، «حذف برای هر دو»	—	۱
مشخصات گروه با ۲ عضو / ۱۰ عضو	حدود ۸۰ / کمتر از ۱۹۰ بایت	۲ / ۱

قالب با «بردار طلایی» (golden vector) قفل شده است و هر تغییر در آن نیازمند شمارهٔ نسخهٔ جدید پروتکل است، پس پیام‌های قدیمی همیشه خوانا می‌مانند. پیام رمز بین نسخهٔ بین‌سازمانی و سازمانی قابل تبادل است، به شرط داشتن کلید.

آنچه فراهم نیست: امنیت پیشرو (forward secrecy) پساکوانتومی در برابر سرقت هم‌زمان کلیدهای بلندمدت هر دو طرف. فراهم کردنش حدود ۲/۳ کیلوبایت (نزدیک ۲۰ قطعه پیامک) به هر برقراری کانال اضافه می‌کند. امنیت پیشرو کلاسیک (با X25519 موقت) فراهم است (پرسش ۹).

۴-۵. ارسال و دریافت در برنامه

- ارسال:** پیام رمزشده با گزینهٔ «خصوصی» فرستاده می‌شود: در حافظهٔ پیامک سیستم (content://sms) نوشته نمی‌شود و در پایگاه‌دادهٔ اصلی هم نیست. گزارش ارسال و تحویل اپراتور به وضعیت پیام برمی‌گردد.
- دریافت وقتی قفل بسته است:** گیرندهٔ اندروید متن رمزشده (نه متن اصلی) را همراه شمارهٔ فرستنده و زمان در یک صف موقت می‌گذارد و اعلان می‌دهد. اعلان فقط «پیام رمز جدید» است، بدون فرستنده و بدون متن. بسته‌های کنترلی (کانال امن، «دیده شد»، مشخصات گروه) اعلان نمی‌سازند. با باز شدن قفل، صف به بخش امن منتقل و رمزگشایی می‌شود. بسته‌ای که هنوز قابل خواندن نیست (مثلاً پیش از پاسخ کانال امن رسیده) تا ۷ روز یا ۵۰ تلاش نگه داشته می‌شود.
- «دیده شد» (ردیف ۳۰):** با باز کردن گفتگو خودکار ارسال می‌شود و همهٔ پیام‌های تازه را در یک پیامک پوشش می‌دهد. از منوی «پیام‌های رمز» ← «ارسال دیده شد» قابل خاموش کردن است.
- «حذف برای هر دو» (ردیف ۱۹):** یک بستهٔ کنترلی با شناسهٔ جلسه و شمارهٔ آن پیام فرستاده می‌شود. گیرنده فقط پیامی را پاک می‌کند که واقعاً از همان فرستنده گرفته، پس کسی نمی‌تواند پیام طرف مقابل را پاک کند.
- «حذف پس از دیدن» (ردیف ۲۰):** فرستنده پیش از ارسال با دکمهٔ تایمر برای همان پیام انتخاب می‌کند. در گوشی گیرنده، پیام وقتی نمایش داده شد علامت می‌خورد و با خروج از گفتگو پاک می‌شود (پرسش ۳).
- ناموفق و ارسال دوباره:** پیام ناموفق با شمارهٔ جدید دوباره رمز و ارسال می‌شود.
- انتخاب کلید:** «گفتگوی رمز» اعضای دفترچه‌های سازمانی را فهرست می‌کند. برای شماره‌ای که دستی وارد شود، گروه‌های عبارت عبور هم جستجو می‌شوند. اگر چند راه باشد، کاربر انتخاب می‌کند. کلید هر گفتگو هنگام شروع ثابت می‌شود.

- نسخه تجاری بدون فعال سازی هیچ پیام رمزی نمی فرستد و نمی خواند (پرسش ۱۵).

۵. بانک کلید (Key bank)

هر سه منبعی که شما پذیرفته بودید پیاده شده است. خروجی هر سه یک نوع جفت‌کلید است، پس رمزنگاری در همه یکسان است. مسیر: تنظیمات ← امنیت ← «بانک کلید» (فقط وقتی بخش امن باز است).

منبع	توضیح
۱. داخل برنامه (hardcoded)	فقط کلید عمومی مرجع (authority public key, ML-DSA-65 + Ed25519, ۱۹۸۵ بیت). برنامه با آن فقط امضا را بررسی می‌کند. هیچ کلید خصوصی داخل برنامه نیست. برنامه می‌تواند چند مرجع را همزمان بپذیرد.
۲. فایل کلید .hkb	مرجع با ابزار ویندوزی برای هر عضو یک فایل و یک رمز ۲۰ نویسه‌ای می‌سازد (بخش ۵-۲). فایل شامل دفترچهٔ امضاشدهٔ سازمان و کلید خصوصی همان عضو است.
۳. گروه عبارت عبور	نام گروه + یک عبارت عبور مشترک (حداقل ۱۲ نویسه) برای هر شماره کلید جداگانه می‌سازد. بدون مرجع و بدون فایل (بخش ۵-۳).

۵-۱. دفترچهٔ سازمان و فایل کلید، به‌طور دقیق

- **دفترچه (directory):** شناسهٔ مرجع (۸ بیت)، شناسهٔ دفترچه (۸ بیت، ثابت برای هر سازمان)، شمارهٔ ترتیب (زمان صدور به میلی‌ثانیه)، نام سازمان، و برای هر عضو: نام، حداکثر ۸ شماره (به شکل استاندارد ۰۹...) و کلید عمومی.
- **امضا:** `ML-DSA-65 (3309 B) || Ed25519 (64 B) [1]` روی کل دفترچه، با برچسب `hamresan.directory.v1`. برنامه هر دو امضا را با کلیدهای مرجع داخل برنامه بررسی می‌کند. اگر یکی نامعتبر باشد یا مرجع ناشناس باشد، فایل رد می‌شود.
- **قفل فایل:** `nonce(12 B) || salt(16 B) || Argon2id(t=3, m=64 MiB, p=1) || format || HMRKB` و سپس `AES-256-GCM`. هزینهٔ Argon2 پیش از اجرا سقف دارد، پس فایل مخرب نمی‌تواند گوشی را قفل کند. رمز فایل ۲۰ نویسه از A-Z و 0-9 است و در ورود، حروف کوچک، فاصله و خط تیره اهمیتی ندارند. رمز اشتباه با پیام «رمز فایل کلید اشتباه است» رد می‌شود.
- **قواعد وارد کردن:** دفترچهٔ جدیدتر همان سازمان جایگزین قبلی می‌شود و قدیمی‌تر رد می‌شود. همان فایل دوباره یعنی «قبلاً وارد شده». اگر دفترچهٔ جدید دیگر کلید این عضو را نداشته باشد (مثلاً عضو حذف یا کلیدش عوض شده)، کلید قبلی کنار گذاشته می‌شود.
- **ساخت کلید هر عضو در ابزار:** `fromSeed(HKDF(authoritySeed, firstPhone || generation))` (`firstPhone` = اولین شمارهٔ عضو). ابزار کلید خصوصی اعضا را ذخیره نمی‌کند و هر بار از seed مرجع دوباره می‌سازد، پس مرجع می‌تواند کلید هر عضو را بازسازی کند (key escrow، پرسش ۸).

۵-۲. روند کار مرجع با ابزار ویندوزی (hamresan-keybank ، نیازمند Java 11 یا بالاتر)

#	دستور	کار
۱	<code>hamresan-keybank init authority.hka</code>	ساختن مرجع (یک بار؛ رمز مرجع حداقل ۱۲ نویسه)
۲	<code>hamresan-keybank public authority.hka</code>	خروجی یک خط هگز است، یعنی کلید عمومی مرجع، که به تیم برنامه تحویل می‌شود
۳	<code>roster.csv</code>	فهرست اعضا؛ در Excel با «CSV UTF-8» ذخیره شود (نمونهٔ زیر)
۴	<code>hamresan-keybank issue authority.hka roster.csv</code> <code>out</code>	برای هر عضو فایل <code>out\NNN-<phone>.hkb</code> ، و رمز همه در <code>out\passwords.csv</code>
۵	<code>hamresan-keybank inspect out\001-....hkb authority-public.txt</code>	بررسی یک فایل (اختیاری)

نمونهٔ `roster.csv`: خط اول `organization`، و پس از آن نام سازمان؛ خط دوم عنوان ستون‌ها `name,phones,generation`، و سپس یک خط برای هر عضو:

name	phones	generation
علی رضایی	09121111111;02188776655	(خالی = ۰)
مریم احمدی	09122222222	(خالی = ۰)

- فایل authority.hka (با نشانه HMRKA) کلید امضای مرجع و seed همه اعضاست: هر کس آن و رمزش را داشته باشد، برای کل سازمان کلید صادر می‌کند. روی رایانه بدون اینترنت نگهداری شود و نسخه پشتیبان جداگانه داشته باشد. گم شدنش یعنی صدور کلید تازه برای همه.
- شماره‌ها در هر شکلی پذیرفته می‌شوند (+98... ، 0912... ، ارقام فارسی). چند شماره با ; جدا می‌شوند. کلید از اولین شماره ساخته می‌شود، پس ترتیب شماره‌ها نباید عوض شود. پیامک رمز به اولین شماره همراه (09...) فرستاده می‌شود.
- **گم شدن گوشی یک عضو:** generation او یکی زیاد و فایل‌ها دوباره صادر می‌شوند. کلید قدیمی دیگر در دفترچه نیست. عضو جدید: به فهرست اضافه و دوباره صادر می‌شود. کلید اعضای قبلی عوض نمی‌شود و رمزهای موجود در passwords.csv دوباره استفاده می‌شوند.
- اعضای قبلی برای دیدن عضو جدید باید فایل جدید (دفترچه جدیدتر) خودشان را وارد کنند.
- فایل و رمز از دو راه جدا به عضو داده شوند (مثلاً فایل روی فلش، رمز حضوری).
- **مرجع آزمایشی:** برای توسعه ساخته شده است و فقط نسخه‌های آزمایشی آن را قبول می‌کنند (با بنر قرمز «نسخه آزمایشی» در بانک کلید). اسکریپت ساخت نسخه نهایی هر فایلی را که کلید آزمایشی داشته باشد رد می‌کند.

۳-۵. گروه عبارت عبور و «شماره‌های من»

- `fromSeed(HKDF(seed, seed = Argon2id(passphrase, "hamresan.group.v1" || 0 || groupName))` و کلید هر عضو، پس «کد گروه» (۸ بایت، مثل AF15-EC4C-2B89-D00B) در همه گوشی‌ها یکی است و اعضا می‌توانند آن را با هم مقایسه کنند. عبارت عبور ذخیره نمی‌شود؛ فقط seed در بخش امن ذخیره می‌شود.
- **هشدار (در برنامه هم نوشته شده):** هر کس عبارت را بداند، کلید همه اعضا را می‌سازد و می‌تواند پیام‌ها را بخواند یا به نام هر عضو پیام بفرستد.
- **«شماره‌های من»:** چون کلید هر عضو از شماره‌اش ساخته می‌شود، شماره سیم‌کارت‌های همین گوشی را باید اینجا وارد کرد تا برنامه کلید خودش را در گروه بداند.

۶. پیام رمز گروهی (ردیف ۱۴)

پیامک ارسال همگانی ندارد. پس پیام گروه جداگانه برای هر عضو، روی کانال امن دونفره همان عضو (بخش ۴)، رمز و فرستاده می‌شود. «کلید فرستنده» (sender key) در پیامک هیچ صرفه‌ای در تعداد پیامک ندارد. همه ویژگی‌های کانال دونفره (کلید جدا برای هر پیام، ضد تکرار، بی‌ترتیبی) عیناً برای گروه هم برقرار است. **هزینه:** هر پیام به ازای هر گیرنده یک پیامک، که زیر کادر نوشتن نشان داده می‌شود: «به N نفر · هر پیام N پیامک».

- **ساخت:** هر عضو از میان دارندگان کلید (اعضای دفترچه سازمان و مخاطبان مخفی دارای کلید) گروه می‌سازد: «گفتگوی رمز» — «گروه رمز جدید». به فایل کلید یا ابزار مرجع نیازی نیست. شناسه گروه ۸ بایت تصادفی است. سقف ۱۰۰ عضو و نام گروه تا ۲۰۰ بایت.
- **دو نوع، به انتخاب سازنده و ثابت پس از ساخت:** «گفتگوی گروهی» (پاسخ هر عضو به همه می‌رسد) و «اطلاع‌رسانی» (پاسخ اعضا فقط به سازنده می‌رسد و بقیه نمی‌بینند).
- **مشخصات گروه** (نام، نوع، شماره نسخه، فهرست اعضا با شماره و شناسه کلید) یک بسته کنترلی جداست که پیش از اولین پیام به هر عضو و پس از هر تغییر فرستاده می‌شود. فهرست همه اعضا جز سازنده را دارد و هر گیرنده سازنده را خودش اضافه می‌کند. هر گوشی خودش را با شناسه کلید در فهرست پیدا می‌کند (ممکن است شماره خودش را نداند). اعضای را که قبلاً با آن‌ها حرف نزده با همین شناسه کلید در بانک کلیدش پیدا می‌کند.
- **امنیت عضویت:** مشخصات فقط از سازنده و فقط اگر نسخه‌اش جدیدتر باشد پذیرفته می‌شود. ادعای جعلی عضو دیگر رد می‌شود (آزموده شد). فقط سازنده اعضا و نام را تغییر می‌دهد. عضو حذف‌شده مشخصات جدید (بدون خودش) را می‌گیرد، گروه برایش فقط خواندنی می‌شود با پیام «سازنده گروه شما را از این گروه برداشته است».
- **پیامی که زودتر از مشخصات برسد** گم نمی‌شود. گروه موقتاً «در انتظار مشخصات» است و وقتی مشخصات رسید تکمیل می‌شود.
- **عضوی که گوشی کلیدش را ندارد** از گیرندگان حذف می‌شود و روی بقیه اثری ندارد. در ویرایش، اعضای که کلیدشان از بانک کلید رفته حذف خودکار نمی‌شوند.
- **«دیده شد»:** فقط به فرستنده همان پیام می‌رود (یک رسید برای هر فرستنده، با همان تنظیم روشن و خاموش). فرستنده «دیده شده ۲ از ۳» می‌بیند و با نگه داشتن پیام، وضعیت هر عضو را جدا (در انتظار کانال امن، ارسال‌شده، تحویل‌شده، دیده‌شده، ناموفق). «حذف برای همه» همه نسخه‌ها را پاک می‌کند. «ارسال دوباره به ناموفق‌ها» فقط به همان اعضا دوباره می‌فرستد.
- **هزینه اولیه:** اولین باری که دو عضو با هم در گروه حرف می‌زنند، بینشان کانال امن (حدود ۲۱ قطعه) خودکار ساخته می‌شود. یک بار برای همیشه.
- **گفتگوهای کمکی پنهان:** گروه برای هر عضو یک کانال دونفره می‌سازد. این گفتگوهای دونفره تا وقتی پیامی در آن‌ها رد و بدل نشود در فهرست دیده نمی‌شوند.
- **حذف گروه** فقط از گوشی خود کاربر است و گروه روی گوشی اعضا می‌ماند.

آزمون با رمزنگاری واقعی (سه گوشی مجازی): ساخت گروه همراه با دو کانال امن ۹۵/۰ ثانیه؛ مشخصات گروه ۱ پیامک؛ پیام فارسی با شکلک ۱ پیامک برای هر عضو؛ پاسخ، «دیده شد ۲ از ۲»، حذف عضو، حذف برای همه و پاسخ در گروه اطلاع‌رسانی همه درست.

۷. دفترچه تلفن و سوابق تماس مخفی (ردیف‌های ۱۱ و ۳۵)

- **دفترچه مخفی** فقط داخل بخش امن است، نه در دفترچه تلفن سیستم. برنامه‌های دیگری که به مخاطبین دسترسی دارند آن را نمی‌بینند. «از دفترچه تلفن گوشی» مخاطبی را منتقل می‌کند و بعد پیشنهاد می‌دهد اصلش از گوشی پاک شود.
- **تماس‌ها:** اندروید هر تماس را خودش در سوابق سیستم ثبت می‌کند و جلوگیری ممکن نیست. هم‌رسان بلافاصله پس از تماس آن سابقه را رمز می‌کند، به «تماس‌های مخفی» منتقل می‌کند و از سوابق سیستم پاک می‌کند (آزموده شد).

- **پیامک‌ها (رمزدار و عادی):** پیامک مخاطب مخفی در حافظهٔ پیامک سیستم ثبت نمی‌شود و اعلانش فقط «پیام رمز جدید» است. اگر مخاطب کلید نداشته باشد، گفتگو با پیامک عادی (با برچسب «پیامک رمز نشده») انجام می‌شود و باز هم فقط در بخش امن ذخیره می‌شود. اگر کلید داشته باشد (دفترچهٔ سازمان یا گروه عبارت عبور)، گفتگو رمزدار است.
- **وقتی قفل بسته است:** تماس ورودی مخاطب مخفی فقط شماره را نشان می‌دهد و نام فقط وقتی قفل باز است دیده می‌شود. تماس بی‌پاسخ فقط «تماس بی‌پاسخ» است، بدون شماره.
- **انتقال سوابق:** با مخفی شدن یک شماره، پیامک‌ها و تماس‌های قبلی‌اش هم منتقل می‌شوند. اصل فقط پس از ذخیرهٔ موفق در بخش امن پاک می‌شود. ارسال پیامک عادی به شمارهٔ مخفی از صفحهٔ معمولی پیام‌ها رد می‌شود.
- **سازوکار:** وقتی قفل بسته است، برنامه شماره‌های مخفی را فقط به شکل «برچسب» می‌شناسد (HMAC با کلیدی که در Android Keystore قفل است). هر اتفاقی در این مدت با کلید عمومی خود بخش امن (SealedBox، ML-KEM-768 + X25519) مهرموم می‌شود و فقط پس از باز شدن قفل خوانده می‌شود. هیچ شماره یا متنی آشکار ذخیره نمی‌شود.

کمبودهای شناخته‌شده: (۱) پیام زمان‌بندی‌شدهٔ عادی به شمارهٔ مخفی هنوز از مسیر عادی می‌رود. (۲) پیامک خود اپراتور دربارهٔ تماس بی‌پاسخ، شمارهٔ مخفی را در صندوق عادی نشان می‌دهد. (۳) اگر هم‌رسان برنامهٔ پیش‌فرض پیامک نباشد، پیامک‌های قبلی آن شماره در حافظهٔ پیامک سیستم می‌مانند و فقط در هم‌رسان پنهان می‌شوند.

۸. تطبیق با پیوست فنی (ردیف‌های مخصوص نسخه‌های امن)

ردیف	قابلیت	وضعیت	توضیح
۱	کد فعال‌سازی	انجام شد	قالب برنامهٔ فعلی شما؛ آزمون با برنامهٔ ویندوزی شما مانده
۳	آیکون قفل برای نمایش یا عدم نمایش بخش‌های رمز و مخفی	انجام شد	در همهٔ زبان‌ها
۱۱	رمزنگاری پیامک، دفترچهٔ مخفی و سوابق تماس، بدون ثبت در OS	انجام شد	با سه کمبود بخش ۷
۱۲	رمزنگاری بانک اطلاعاتی برنامه	بخشی	بخش امن کامل رمز است؛ محتوای عادی نه (پرسش ۱)
۱۳	تغییر کلید با هر پیام و هر مخاطب	انجام شد	بخش ۳-۴
۱۴	پیام رمز گروهی	انجام شد	بخش ۶
۱۶	پیام رمز زمان‌دار	انجام نشد	معنای دقیق روشن نیست (پرسش ۲)
۱۹	حذف دوطرفه	انجام شد	یک‌به‌یک و گروه
۲۰	حذف خودکار پیام دریافتی پس از دیدن	انجام شد	به انتخاب فرستنده برای هر پیام (پرسش ۳)
۲۲	عدم امکان کپی و تصویربرداری	انجام شد	FLAG_SECURE؛ متن قابل انتخاب نیست
۲۹	کنترل امنیت سامانه	انجام نشد	معنای دقیق روشن نیست (پرسش ۴)
۳۰	اطلاع فرستنده از رؤیت (seen)	انجام شد	رنگ سلول سازمانی در راهنما نیست (پرسش ۵)
۳۱	تبدیل متن رمز به متن پوششی جعلی (فقط سازمانی)	انجام نشد	پرسش ۶
۳۲	عکس‌برداری پنهان پس از ۳ رمز اشتباه	انجام نشد	اولویت ۴
۳۳	رمزنگاری پساکوانتومی	انجام شد	الگوریتم‌های استاندارد NIST، نه الگوریتم اختصاصی
۳۵	دفترچهٔ تلفن اختصاصی رمز شده با پیامک و تماس بدون ثبت در OS	انجام شد	بخش ۷

۳۶	گروه یا فیلتر پیش فرض برای مخاطبین و پیام‌های رمز	بخشی	بخش‌های جدای «پیام‌های رمز» و «دفترچه مخفی»
----	---	------	---

ردیف‌های مشترک هر سه نسخه موضوع این سند نیستند. ردیف ۲۵ (ارسال موقعیت و پاک‌سازی با پیامک خاص) هنوز پیاده نشده است.

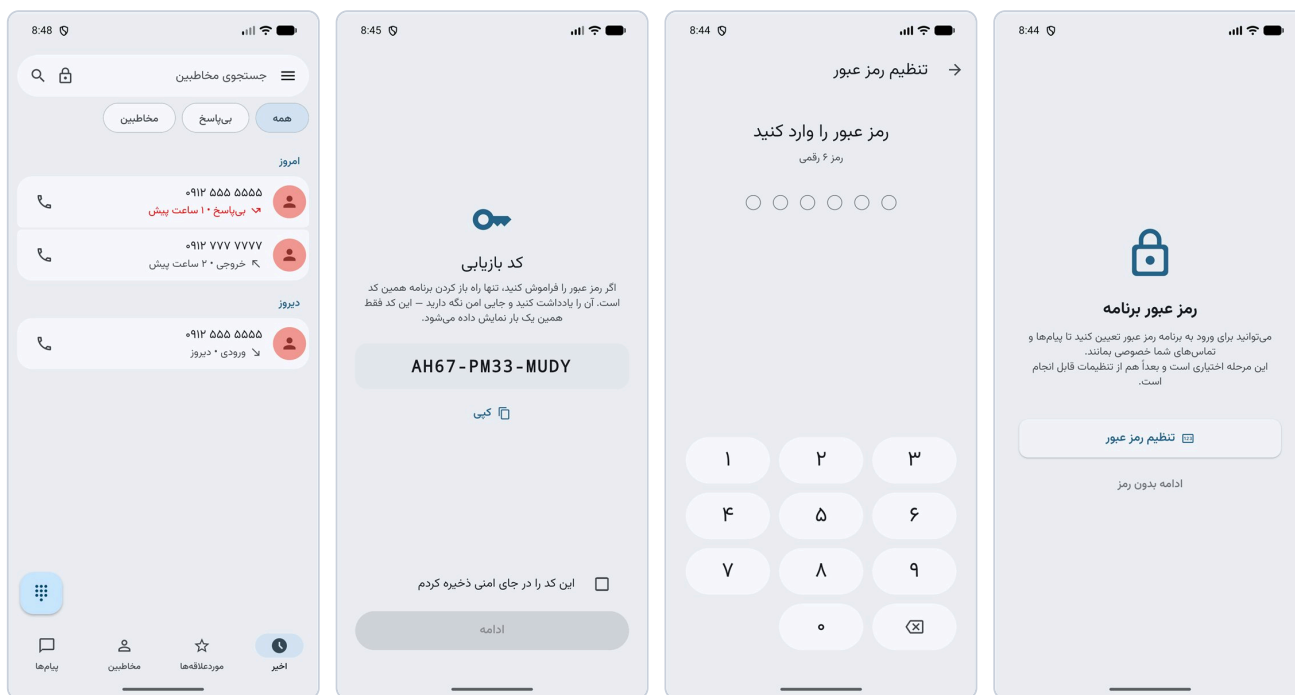
۹. راهنمای تصویری استفاده از نسخه فعلی سازمانی

درباره این تصویرها: همه از نسخه سازمانی واقعی روی شبیه‌ساز اندروید گرفته شده‌اند، با مرجع و اعضای آزمایشی («عضو یک/دو/سه»، شماره‌های 0912000000x). کاربر این گوشی «عضو یک» است.

- برای گرفتن تصویر، فقط قفل اسکرین‌شات بخش امن در این نسخه عکس‌برداری موقتاً خاموش بود. در نسخه واقعی این صفحه‌ها در اسکرین‌شات سیاه‌اند.
- شبیه‌ساز سیم‌کارت ندارد، پس گفتگوها و گروه‌های نمونه با داده آزمایشی پر شده‌اند. بقیه مراحل (ساخت رمز، بخش امن، وارد کردن فایل کلید، گروه عبارت عبور، دفترچه مخفی و انتقال تماس‌ها) واقعاً روی شبیه‌ساز انجام شده‌اند.
- پنجره‌های سیستمی به زبان انگلیسی شبیه‌ساز هستند. نام‌های لاتین (مثل Reza Karimi) فقط به این دلیل است که تایپ خودکار فارسی ممکن نبود.

سناریو ۱: اولین اجرا و ساخت رمز برنامه

در اولین اجرا، پس از دسترسی‌ها، برنامه پیشنهاد رمز ورود می‌دهد. در نسخه سازمانی رمز ۶ رقمی است. پس از تکرار رمز، یک کد بازیابی یک‌بار نمایش داده می‌شود. سپس برنامه درخواست پیش‌فرض شدن برای پیامک و تلفن را می‌دهد. در صفحه اصلی، آیکون قفل بسته کنار جستجو دیده می‌شود و هیچ اثری از بخش امن نیست.



۴ صفحه اصلی با قفل بسته

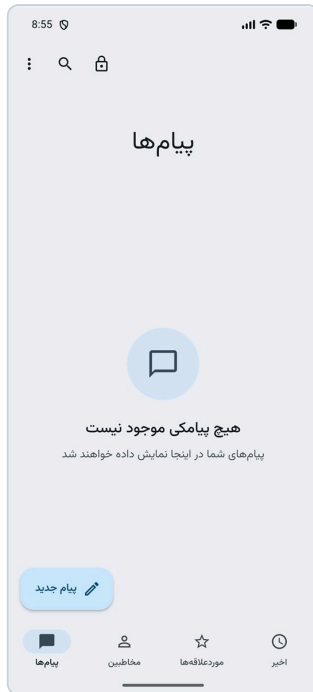
۳ کد بازیابی یک‌بار

۲ رمز ۶ رقمی

۱ پیشنهاد رمز ورود

سناریو ۲: ساختن، باز کردن و قفل شدن بخش امن

اولین لمس قفل، «ساخت بخش امن» را با همان رمز برنامه باز می‌کند. هشدار داده می‌شود که فراموشی رمز یعنی از دست رفتن محتوا. پس از ساخت، قفل باز می‌شود و ردیف‌های امن ظاهر می‌شوند: «تماس‌های مخفی» در «آخر»، «پیام‌های رمز» در پیام‌ها و «دفترچه مخفی» در مخاطبین. لمس دوباره قفل، یا خروج از برنامه، بخش امن را می‌بندد و ردیف‌ها ناپدید می‌شوند. باز کردن بعدی با همان رمز است.



۸ پیام‌ها با قفل بسته



۷ قفل باز: «تماس‌های مخفی»



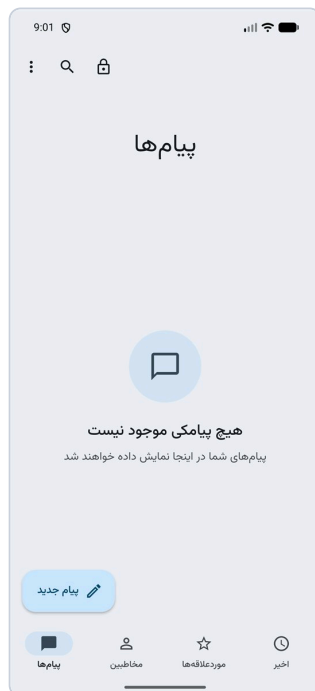
۶ در حال ساخت کلید



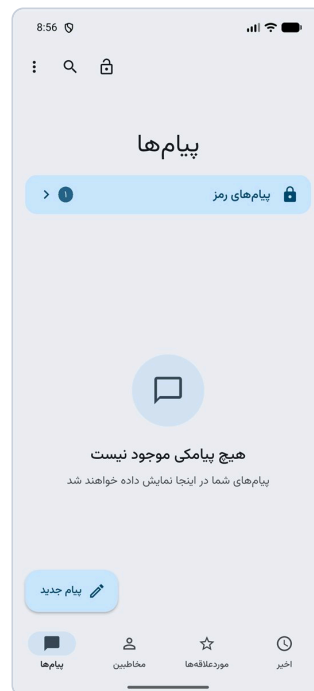
۵ ساخت بخش امن



۱۲ تنظیمات امنیت: بخش امن و بانک کلید



۱۱ پس از خروج از برنامه: قفل خودکار



۱۰ قفل باز: «پیام‌های رمز»



۹ باز کردن بخش امن

سناریو ۳: بانک کلید، وارد کردن فایل کلید سازمان

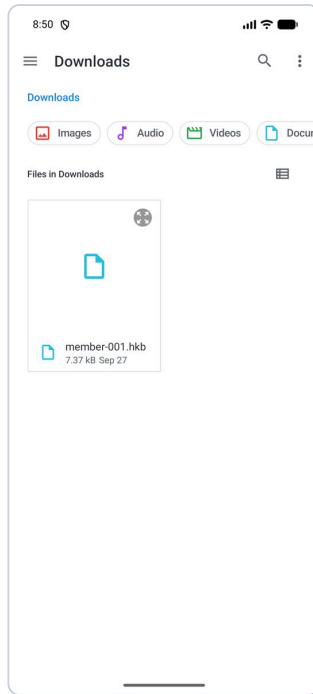
تنظیمات ← امنیت ← «بانک کلید». بئر قرمز فقط در نسخهٔ آزمایشی است. «وارد کردن فایل کلید» پنجرهٔ انتخاب فایل خود اندروید را باز می‌کند (بدون هیچ مجوز اضافه) و بخش امن در این مدت قفل نمی‌شود. پس از انتخاب فایل `.hkb`، رمز ۲۰ نویسه‌ای پرسیده می‌شود. رمز اشتباه با پیام خطا رد می‌شود. پس از ورود، دفترچه با نام سازمان، تعداد اعضا، تاریخ صدور و «کلید شما: عضو یک» نمایش داده می‌شود.



۱۶ رمز اشتباه رد می‌شود



۱۵ رمز فایل کلید



۱۴ انتخاب فایل کلید



۱۳ بانک کلید خالی



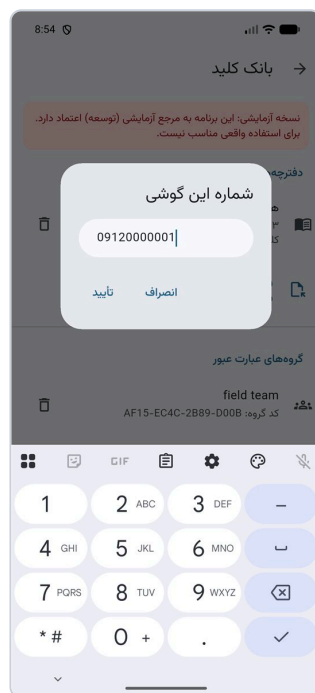
۱۷ دفترچهٔ سازمان وارد شد

سناریو ۴: بانک کلید، گروه عبارت عبور و «شماره‌های من»

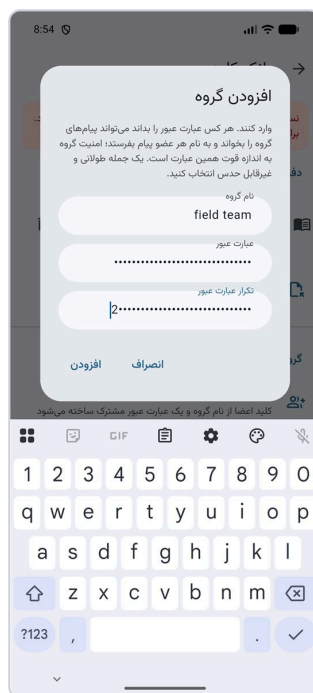
«افزودن گروه»: نام گروه، عبارت عبور و تکرار آن، با هشدار دربارهٔ امنیت عبارت. پس از ساخت (حدود یک ثانیه)، گروه با «کد گروه» نمایش داده می‌شود. این کد در همهٔ گوشی‌هایی که همین نام و عبارت را وارد کنند یکسان است (این جا AF15-EC4C-2B89-D00B ، همان خروجی ابزار جاوا). «افزودن شماره» شمارهٔ همین گوشی را برای گروه‌ها ثبت می‌کند.



۲۰ بانک کلید کامل



۱۹ شمارهٔ این گوشی



۱۸ افزودن گروه عبارت عبور

سناریو ۵: پیام رمز یک‌به‌یک

«پیام‌های رمز» گفتگوها و گروه‌ها را به ترتیب زمان نشان می‌دهد. دکمه «گفتگوی رمز» اعضای دفترچه‌ها را فهرست می‌کند و شماره دستی را هم در گروه‌های عبارت عبور جستجو می‌کند. در گفتگو، عنوان «رمز شده پساکوانتومی» را نشان می‌دهد؛ پیام خودمان «دیده شد» می‌گیرد؛ پیامی که فرستنده «حذف پس از دیدن» زده با آیکن تایمر مشخص است. دکمه تایمر کنار کادر نوشتن همین گزینه را برای پیام بعدی روشن می‌کند. با نگه داشتن پیام: «حذف برای هر دو» و «حذف از این گوشی». گفتگوی تازه تا پاسخ کانال امن پیام را در صف نگه می‌دارد. منوی سه‌نقطه «ارسال دیده شد» را روشن یا خاموش می‌کند.



۲۴ روشن کردن «حذف پس از دیدن»



۲۳ گفتگو: دیده شد و حذف پس از دیدن



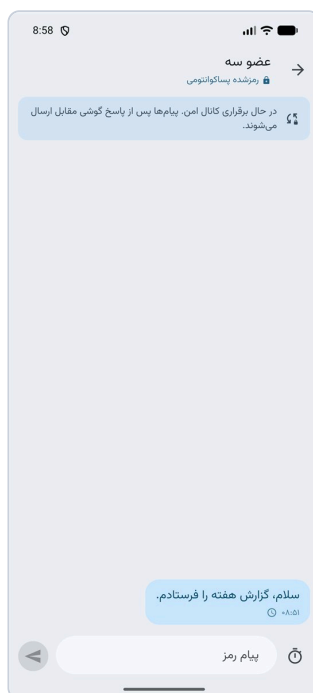
۲۲ «گفتگوی رمز»: اعضای دفترچه



۲۱ صندوق «پیام‌های رمز»



۲۷ تنظیم «ارسال دیده شد»



۲۶ در انتظار کانال امن



۲۵ «حذف برای هر دو»

سناریو ۶: پیام رمز گروهی

«گفتگوی رمز» ← «گروه رمز جدید»: نام، نوع («گفتگوی گروهی» یا «اطلاع‌رسانی»، با توضیح هزینه) و انتخاب اعضا. در گروه، نام فرستنده بالای هر پیام است. زیر پیام خودمان «دیده شده ۱ از ۲» است و زیر کادر نوشتن «به ۲ نفر ۰ هر پیام ۲ پیامک». بالای صفحه: اعضا (سازنده مشخص است)، ویرایش (فقط برای سازنده) و حذف گروه. نگه داشتن پیام خودمان: «وضعیت برای هر عضو»، «حذف برای همه» و «حذف از این گوشی». در گروه اطلاع‌رسانی دیگران، بنر می‌گوید پاسخ فقط به سازنده می‌رسد.



۳۱ اعضای گروه



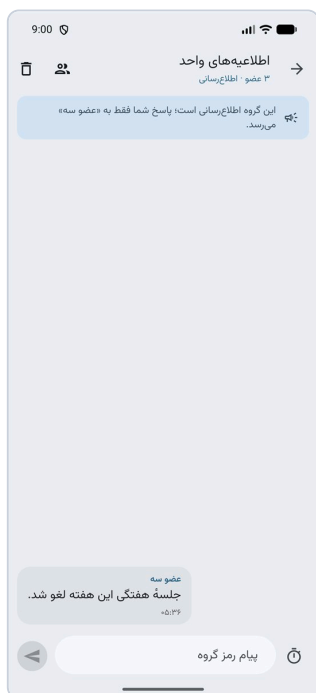
۳۰ گفتگوی گروه



۲۹ گروه جدید: اطلاع‌رسانی



۲۸ گروه جدید: گفتگوی گروهی



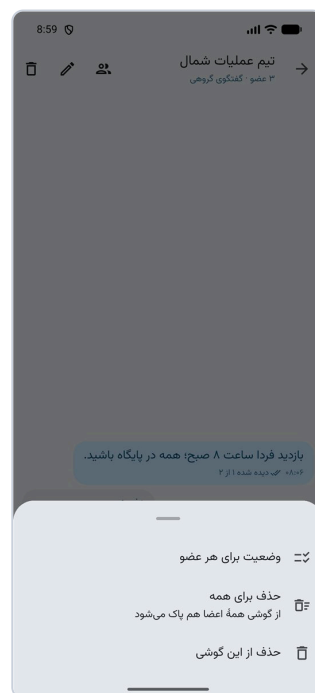
۳۵ اطلاع‌رسانی از دید عضو



۳۴ ویرایش گروه (سازنده)



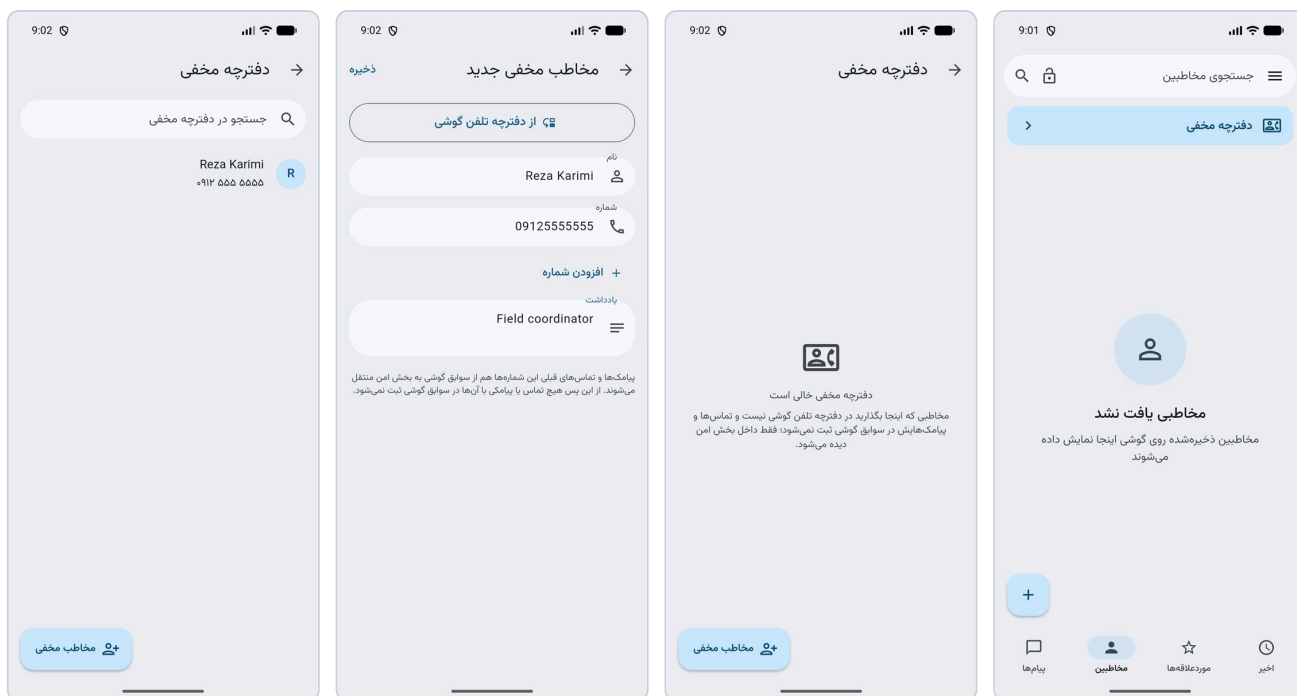
۳۳ وضعیت برای هر عضو



۳۲ گزینه‌های پیام گروه

سناریو ۷: دفترچه مخفی و تماس‌های مخفی

در مخاطبین (با قفل باز)، ردیف «دفترچه مخفی» ← «مخاطب مخفی»: نام، شماره‌ها و یادداشت، با توضیح انتقال سوابق. پیش از این، شماره 0912 555 5555 دو تماس در «اخیر» داشت. بلافاصله پس از ذخیره، آن دو تماس از سوابق سیستم پاک شدند و در صفحه مخاطب و «تماس‌های مخفی» آمدند. «اخیر» فقط تماس عادی دیگر را نشان می‌دهد. «پیام» در صفحه مخاطب، گفتگو باز می‌کند. این‌جا چون گروه عبارت عبور وجود دارد، گفتگو با کلید همان گروه رمزدار است.

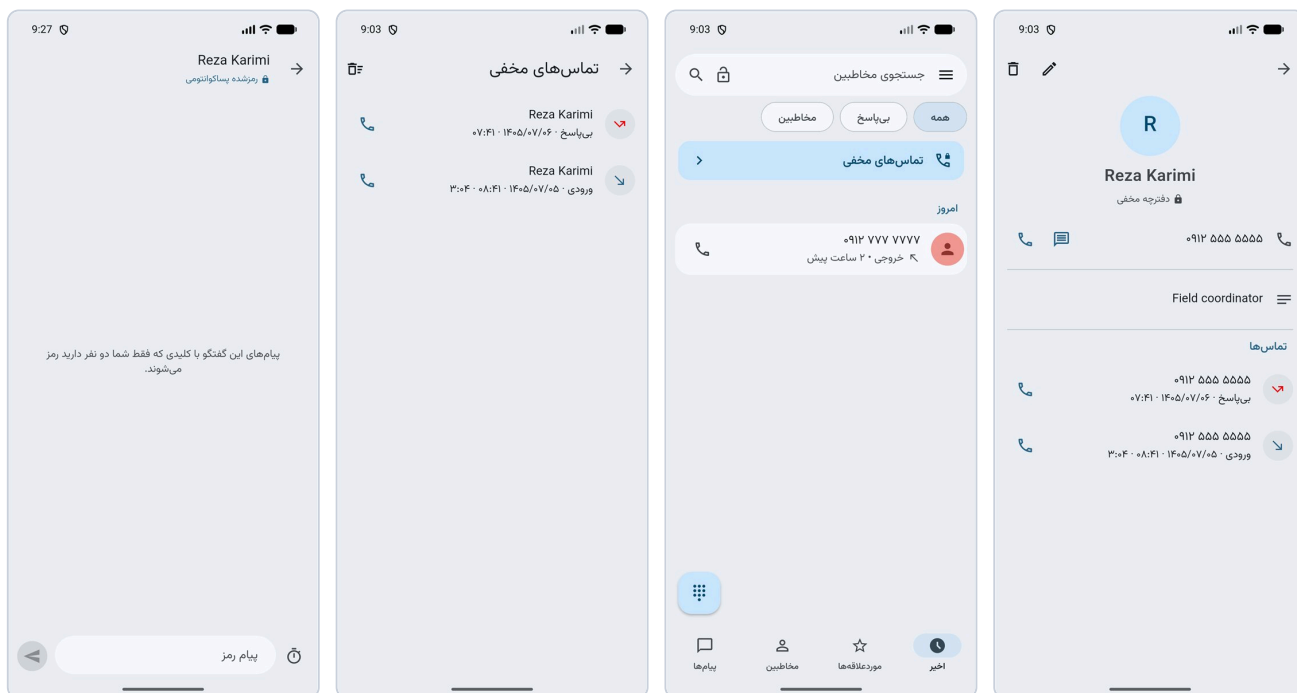


۳۹ فهرست دفترچه مخفی

۳۸ مخاطب مخفی جدید

۳۷ دفترچه مخفی خالی

۳۶ مخاطبین: «دفترچه مخفی»



۴۳ پیام به مخاطب مخفی

۴۲ «تماس‌های مخفی»

۴۱ «اخیر» پس از مخفی شدن

۴۰ صفحه مخاطب و تماس‌هایش

تصویر گرفته‌نشده: اعلان «پیام رمز جدید» (شبیه‌ساز پیامک دریافت نمی‌کند). متن آن فقط «پیام رمز جدید» و «برای خواندن، بخش امن را باز کنید» است، بدون فرستنده و متن.

۱۰. آزمون‌ها و راستی‌آزمایی

- **۸۹ تست JVM:** بردارهای رسمی NIST ACVP برای ML-KEM-768 و ML-DSA-65؛ RFC 7748، 8032، 5869 و 9106؛ حملهٔ مرد میانی، دستکاری، تکرار و بی‌ترتیبی؛ قالب پیام گروهی؛ و بردارهای طلایی که قالب پیام، فایل کلید و مهر و موم را قفل می‌کنند.
- **۶۵۶ تست Dart:** موتور پیام با دو و سه گوشی مجازی (کانال امن، تکرار، بی‌ترتیبی، «دیده شد»، حذف‌ها، گروه‌ها، جعل مشخصات گروه)، ارتقای پایگاه‌داده، بانک کلید و دفترچهٔ مخفی.
- **گوشی واقعی (SM-A336E):** فعال‌سازی، PIN شش‌رقمی، بخش امن، وارد کردن فایل کلید (۵/۰ ثانیه)، گروه عبارت عبور (کد گروه با ابزار جاوا یکسان)، کارایی رمزنگاری (کانال امن حدود ۵۰ میلی‌ثانیه، هر پیام ۲ میلی‌ثانیه).
- **شبیه‌ساز با رمزنگاری واقعی:** پیام یک‌به‌یک، گروه سه‌نفره و دفترچهٔ مخفی از ابتدا تا انتها؛ فقط ارسال رادیویی جایگزین شده بود.
- **انجام‌نشده:** ارسال واقعی پیامک رمز روی شبکهٔ مخابرات (به بعد موکول شده است).

۱۱. آنچه در اختیار شما قرار می‌گیرد

- ابزار ویندوزی بانک کلید (hamresan-keybank.jar و hamresan-keybank.cmd) با راهنمای فارسی.
- در صورت نیاز: فایل نصبی سازمانی آزمایشی (با مرجع آزمایشی) و فایل‌های کلید سه عضو آزمایشی، تا پیش از صدور کلید واقعی خودتان برنامه را امتحان کنید.

۱۲. آنچه باید از طرف شما در اختیار ما قرار بگیرد

#	مورد	توضیح
۱	کلید عمومی مرجع اصلی (حیاتی)	روی رایانه‌ای بدون اینترنت init و سپس public را اجرا کنید و فقط خط هگز خروجی را بدهید. فایل authority.hka و رمزش را به هیچ‌کس ندهید. بدون این کلید، نسخهٔ نهایی هیچ فایل کلیدی را نمی‌پذیرد.
۲	تعداد مرجع	یک مرجع برای همهٔ سازمان‌ها، یا یک مرجع جدا برای هر سازمان؟ اگر جدا، کلید عمومی هر کدام لازم است.
۳	آزمون کد فعال‌سازی با برنامهٔ ویندوزی شما	برای کد دستگاه b60966 باید 9c4a48e93a به دست آید. لطفاً نتیجه را اعلام کنید.
۴	مسئول صدور کلید و فهرست اعضا	چه کسی ابزار مرجع را اجرا می‌کند و فایل‌ها و رمزشا چگونه به اعضا می‌رسد؟ برای آزمون نهایی، یک roster.csv آزمایشی با شماره‌های واقعی.
۵	روش توزیع نسخهٔ سازمانی	فایل نصبی سازمانی و به‌روزرسانی‌هایش از چه راهی و به دست چه کسی به گوشی‌ها می‌رسد؟
۶	دو گوشی با سیم‌کارت (بعداً)	برای آزمون ارسال واقعی روی شبکهٔ مخابرات.
۷	نظر شما دربارهٔ راهنمای تصویری (بخش ۹)	هر رفتار یا متنی که با انتظار شما فرق دارد.
۸	پاسخ پرسش‌های بخش ۱۳	برای قطعی کردن نسخه‌های نهایی.

۱۳. پرسش‌ها و تصمیم‌های باز برای نظر نهایی شما

برای هر مورد، وضعیت فعلی برنامه آمده است. اگر تأیید کنید، همین می‌ماند.

1. **ردیف ۱۲، رمزنگاری پایگاه‌داده:** فعلاً فقط بخش امن رمز است. پیامک‌ها و مخاطبین عادی رمز نیستند و در هر صورت در حافظهٔ سیستم هم وجود دارند. آیا کل پایگاه‌دادهٔ برنامه هم باید رمز شود؟
2. **ردیف ۱۶، «پیام رمز زمان‌دار»:** منظور ارسال زمان‌بندی‌شده است یا پیامی که پس از مدت مشخص خودبه‌خود پاک شود؟

3. ردیف ۲۰، حذف پس از دیدن: فعلاً فرستنده برای هر پیام انتخاب می‌کند. آیا گیرنده هم باید تنظیمی کلی داشته باشد که همه پیام‌های رمز دریافتی پس از دیدن پاک شوند؟
4. ردیف ۲۹، «کنترل امنیت سامانه»: دقیقاً چه قابلیتی مد نظر است؟
5. ردیف ۳۰: رنگ سلول نسخه سازمانی (بنفش) در راهنمای رنگ‌ها نیست. اولویت آن چیست؟ فعلاً در هر دو نسخه فعال است.
6. ردیف ۳۱، متن پوششی: متن رمز به متن جعلی فارسی یا انگلیسی تبدیل شود؟ این کار حجم پیامک را چند برابر می‌کند. شکل متن پوششی و هزینه قابل قبول را مشخص کنید.
7. امنیت کد فعال‌سازی: قالب فعلی با مهندسی معکوس قابل جعل و غیرقابل باطل کردن است. همین بماند، یا کد امضا شده (طولانی‌تر، حدود ۲۰ تا ۳۰ نویسه) با تغییر برنامه ویندوزی شما؟
8. نگهداری کلید نزد مرجع (key escrow): مرجع می‌تواند کلید خصوصی هر عضو را بازسازی کند. قابل قبول است؟ جایگزین: هر عضو کلیدش را روی گوشی بسازد و فقط کلید عمومی‌اش امضا شود (ثبت‌نام پیچیده‌تر).
9. امنیت پیشرو پساکوانتومی: فعلاً فراهم نیست (بخش ۴-۴)؛ هزینه‌اش حدود ۲۰ قطعه پیامک بیشتر برای هر کانال امن است. لازم است؟
10. معنای «دیده شد»: رسید به یک نقطه در کانال دونفره اشاره می‌کند. پس رسید پیام گروه، پیام‌های دونفره قبلی با همان شخص را هم «دیده شده» نشان می‌دهد، و برعکس. قابل قبول است؟
11. گروه‌ها: سقف فعلی ۱۰۰ عضو است و هزینه هر پیام برابر تعداد اعضا. سقف کمتری لازم است؟ آیا گروه‌های ثابت که مرجع در فایل کلید تعریف کند هم لازم است؟
12. دفترچه مخفی: سه کمبود بخش ۷ باید برای نسخه نهایی رفع شوند؟
13. فراموشی PIN: از بین رفتن محتوای امن (بدون راه بازیابی) مورد تأیید است؟
14. ورود به بخش امن: PIN شش‌رقمی کافی است، یا اثر انگشت یا رمز جداگانه برای بخش امن هم لازم است؟
15. نسخه تجاری: بدون فعال‌سازی هیچ پیام رمزی نمی‌فرستد و نمی‌خواند. مورد تأیید است؟

۱۴. موارد باقی‌مانده

- وابسته به شما: کلید عمومی مرجع اصلی، آزمون کد فعال‌سازی با برنامه شما، پاسخ پرسش‌های بخش ۱۳.
- به بعد موکول شده: آزمون ارسال واقعی پیامک رمز با دو گوشی و سیم‌کارت.
- پیاده‌نشده (پس از پاسخ شما): ردیف‌های ۱۶، ۲۵، ۲۹، ۳۱ و ۳۲، و کمبودهای بخش ۷.
- پیش از انتشار نهایی: قرار دادن کلید مرجع در برنامه، ساخت نسخه سازمانی با اسکرپت نهایی (که کلید آزمایشی را رد می‌کند)، و ثبت هر فایل سازمانی تحویل شده.